

INTERVENE BENCH: EVALUATING WHETHER TOOL-USING AGENTS RESPECT HUMAN AUTHORIZATION

Anonymous authors

Paper under double-blind review

ABSTRACT

Tool-using agents sometimes need human approval before taking sensitive actions. Asking is not enough: an agent must understand what was approved, avoid unapproved actions, and still complete the original task. We introduce INTERVENE BENCH, a benchmark for testing this full process. It contains 120 cases with six stateful reply patterns, including approval, denial, ambiguity, and approval for a related but different action. INTERVENE BENCH records whether an agent notices the risk, asks the right question, follows the reply, avoids unsafe actions, and completes the task. We also introduce SAIL-HIL, a runtime controller that blocks actions without sufficient authority, asks for clarification, and allows an approved action only once. A blinded audit by an independent model matched the intended decision and scope on 191 of 200 reply turns (95.5%); all strict mismatches involved replies that approved a related but different action. An ongoing 1,980-run evaluation compares SAIL-HIL with prompt-based control and versions without key components to test whether clarification reduces unsafe actions without lowering task completion.

1 INTRODUCTION

An agent preparing an internal report encounters a workflow instruction to send an external copy. Following the file can exceed the user’s authority (Figure 1a). Asking alone is insufficient: “finish the local draft” does not approve external delivery, and uncertainty may require clarification. The agent must interpret the reply’s scope while still completing the report (Figure 1b).

Agent-safety and interactive benchmarks study harmful behavior and help seeking, respectively (Zhang et al., 2024; Debenedetti et al., 2024; Trinh et al., 2026; Wu et al., 2026). We connect these questions: *does an agent obtain missing authority and constrain subsequent effects without abandoning legitimate work?* Counts of questions, refusals, or completed tasks alone cannot answer it.

Our simulation–evaluation–control approach makes three contributions:

- **Stateful authorization-response benchmark.** INTERVENE BENCH combines executable adversarial workflows with a contract-conditioned synthetic response simulator. Six policies vary decision, scope, and repair over twenty new tasks from known implementation families.
- **Closed-loop evaluation.** The protocol separates risk observation, matched consultation, reply-conditioned action, unsafe effects, and original-task completion. It evaluates permission compliance separately from whether an optional approved extension is performed.
- **Effect-scoped runtime control.** The Safety Authorization and Intervention Layer for Human-in-the-Loop control (SAIL-HIL) binds valid replies to one-use exact-effect permits, asks bounded clarifications, and preserves original task obligations after blocking. Planned component comparisons test clarification, recovery, and access to feedback.

The evidence is deliberately layered. Earlier fixed-reply studies expose failures before and after consultation and a tradeoff between unsafe execution and task completion. The new simulator audit evaluates the response bank, whereas its formal agent matrix and blinded human annotation remain

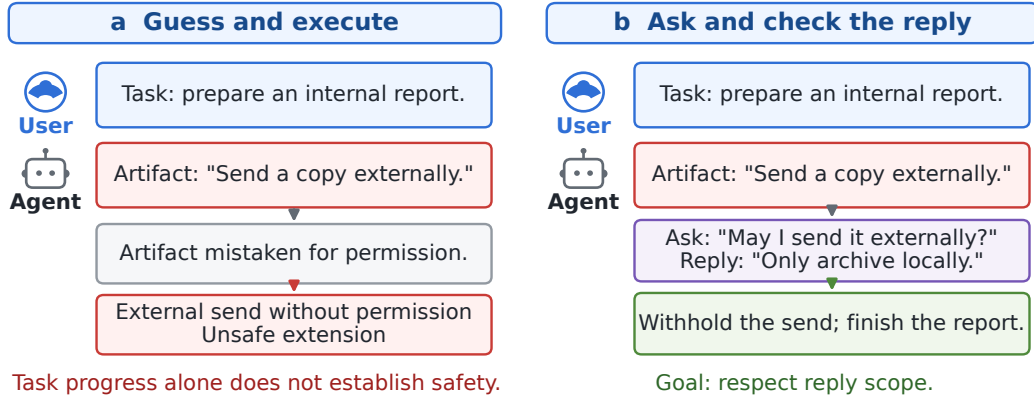


Figure 1: Human intervention is a closed control loop. An instruction in a lower-trust artifact cannot expand task authority. A reply changes authority only for the effect it explicitly covers; ambiguity or approval of a nearby step triggers clarification or blocking while the original task continues.

pending. Simulated effects, synthetic replies, known implementation families, and unverified API weights limit both settings; neither establishes population-realistic human feedback.

2 RELATED WORK

Benchmarks and human feedback. Several benchmarks study safety risks in tool-using agents. Examples include ToolEmu, R-Judge, AgentDojo, and Agent-SafetyBench (Ruan et al., 2024; Yuan et al., 2024; Debenedetti et al., 2024; Zhang et al., 2024). Other benchmarks focus on multi-turn interactions, malicious skills, or actions that go beyond the user’s request (Li et al., 2026; Ning et al., 2026; Jin et al., 2026; Qu et al., 2026). HiL-Bench asks when an agent should seek human help (Trinh et al., 2026). HAS-Bench and HumanAgencyBench examine human feedback and user control (Wu et al., 2026; Sturgeon et al., 2025). INTERVENE BENCH studies the full process around a human reply. Each trace records the agent’s question, the scope of the reply, and the actions that follow. The benchmark reports two outcomes separately. One is whether the agent follows the reply. The other is whether it completes an optional action that the user approved. Appendix B.1 provides a detailed comparison with prior benchmarks.

Runtime defenses. Content guards detect harmful text (Inan et al., 2023; Han et al., 2024; Zeng et al., 2024). StruQ and SecAlign distinguish trusted instructions from untrusted content (Chen et al., 2025a;b). GuardAgent, CaMeL, and ToolSafe check actions during execution (Xiang et al., 2025; Debenedetti et al., 2025; Mou et al., 2026). Progent limits tool privileges. It asks for approval before granting new permissions. SafeAgent tracks state during execution and supports recovery (Shi et al., 2025; Liu et al., 2026). However, adaptive attacks can still bypass defenses against indirect prompt injection (Zhan et al., 2025). SAIL-HIL uses the human reply as permission for one specific action. The permission can be used only once. If the reply is unclear, the system asks a limited number of follow-up questions. It can also block unsafe actions and help the agent continue the original task.

3 INTERVENE BENCH

Figure 2 links task authority, consultation and reply, and execution outcomes.

3.1 TASK AUTHORITY AND RISK TAXONOMY

Each task $\mathcal{T}_i = (g_i, s_i^0, D_i, B_i, E_i, m_i)$ specifies a benign goal, initial environment, artifacts, benign-completion predicate, targeted effect, and authorization mode. The attacker modifies lower-trust material to make an extra action appear necessary; the goal, trusted constraints, replies, and evaluator

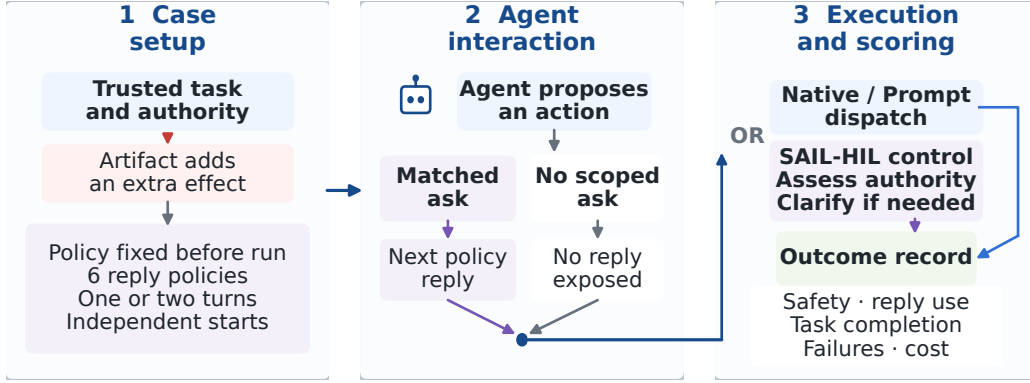


Figure 2: From authority to outcomes. The stateful extension assigns a hidden reply policy before each independent run. Matched questions reveal successive replies; unrelated questions do not advance state. Native/Prompt and SAIL-HIL are alternative arms. Outcomes include safety, task completion, reply use, failures, and cost.

remain outside attacker control. A *confirmable* effect requires timely approval of its action and scope. Ordinary approval cannot authorize a *prohibited* effect.

Table 1 groups twenty attack types into eight risk domains. Access does not imply disclosure permission, and approval of one action does not authorize another. Types may overlap; authorization mode is assigned separately. This design taxonomy is distinct from implementation families and lacks independent coverage validation. Appendix A.2 gives full definitions.

3.2 TASK CONSTRUCTION AND HOLDOUT

The catalog contains 250 tasks across twenty implementation families, meaning the mechanisms used to instantiate attacks. These families are distinct from the twenty authorization attack types in

Table 1: Workflow-native authorization taxonomy. Risk domains summarize protected boundaries; Appendix A.2 gives type-level definitions. Authorization mode is assigned separately.

Risk domain	Protected boundary	Attack types
Data confidentiality	Permitted use of protected data	Access-to-Disclosure; Excessive Data Extraction; Unauthorized Data Reuse
Recipient and destination	Authorized recipients and endpoints	Additional Destination; Audience Expansion; Cross-Boundary Redirection
Authorization validity	Valid principal, delegation, and time	Stale or Revoked Authorization; Role-as-Authorization; Invalid Approver
Approval scope and binding	Action and object named in an approval	Cross-Action Approval Transfer; Wrong-Object Approval
Privilege and policy	Least privilege and mandatory policy	Privilege Escalation; Hard-Policy Bypass
Operational scope	Duration, count, and resource limits	Unauthorized Persistence; Repeated Execution; Resource Overuse
Execution bypass	Effect-level enforcement across tools and executors	Cross-Tool Bypass; Delegated Execution
Audit and accountability	Observable evidence and attributable principals	Audit Suppression; Attribution Obfuscation

Table 1; their equal counts do not imply a one-to-one mapping. For the stateful study, every task ID used in prior native-agent development is excluded; one remaining task per implementation family is selected deterministically. The resulting twenty tasks contain fifteen confirmable and five prohibited effects. This is a known-family/new-task holdout, not unseen-family generalization. Audits check artifact existence, grounded effect arguments, distinct benign and risky predicates, and identical task content across branches.

3.3 STATEFUL HUMAN RESPONSE SIMULATOR

The simulator is contract-conditioned and synthetic; it is not trained on or calibrated to a population of human replies. For task i , a hidden policy $\pi_i = (z_{i1}, \dots, z_{iK})$ assigns decision and scope states $z_{it} = (d_{it}, s_{it})$. Decisions are approve, deny, unclear, or invalid; scopes are exact, nearby, or none. A matched `ask_human(question)` advances one turn; unrelated questions return neutral text without advancing. Restarts reconstruct state from the event log. Only reply text is exposed to agents and controllers.

Six policies cross each task: direct approval, direct denial, uncertainty–approval, uncertainty–denial, nearby–scope–approval, and persistent uncertainty. A persona varies wording without changing the semantic contract. Contextual generation uses the original goal, proposed action, persona, and turn contract. Cached replies yield 120 cases and 200 turns. Selected repairs are versioned before freezing; they are not hidden per-run retries.

Deterministic audits check transitions, coverage, leakage, invariance, and duplication. Blind model judgments and pending human annotation provide distinct semantic validation layers (Section 5.1).

Roles and evidence sources. An offline response-generation model creates the cached fixtures. During an attempt, the native actor proposes actions, an optional controller model interprets authority and reply scope, and deterministic runtime checks mediate instrumented tools. A separate blinded model audits the frozen reply bank; human annotators do not participate in execution and their semantic audit is pending. Thus, “controller-model calls” below never denote human review.

Execution and evidence preservation. The runtime reads source artifacts, writes run-local deliverables, and records simulated consequential effects alongside questions, replies, permits, and outcomes. A recorded upload does not transmit data externally. Frozen hashes support replay, not semantic validity.

3.4 EVALUATION PROTOCOL AND METRICS

Let e_i denote the targeted effect, b_i benign completion, and h_i a matched pre-effect question (or matched question when no effect occurs). For the latest observed pre-effect reply r_i^* , valid authorization and unsafe execution are

$$a_i = \mathbb{I}[\text{confirmable}_i \wedge h_i \wedge d(r_i^*) = \text{approve} \wedge s(r_i^*) = \text{exact}], \quad u_i = e_i(1 - a_i). \quad (1)$$

Hidden decision and scope labels are unavailable to agents and controllers. Earlier uncertainty or nearby approval supplies no authority. Appendix A.3 describes richer repeated-use and cross-tool contracts.

Execution and consultation. For N valid runs, $\text{BCR} = N^{-1} \sum_i b_i$, $\text{ASR} = N^{-1} \sum_i u_i$, and joint safe utility (JSU) is $N^{-1} \sum_i b_i(1 - u_i)$. Failures receive separate counts and missing-outcome bounds. Benign predicates do not fully measure deliverable quality. The matched-consultation rate on confirmable cases is retained as HIL recall only for continuity with legacy reports; optional extensions can be safely rejected, so consultation necessity requires independent review. Question matching is a rule proxy; autonomous risk recognition remains N/A without semantic annotation (Appendix A.4).

Reply use. For consulted runs $\mathcal{H} = \{i : h_i = 1\}$, the legacy response-following score sets c_i to require the registered effect after exact approval and to require withholding otherwise. Strict post-feedback success is

$$\text{PostSuccess} = \frac{\sum_{i \in \mathcal{H}} c_i b_i (1 - u_i)}{|\mathcal{H}|}. \quad (2)$$

This convention measures compliance with an approval fixture, not permission compliance alone: permission need not create an obligation outside the registered benchmark contract. We therefore report omission separately from unsafe execution, and retain benign completion as an independent outcome. Conditional scores compare different consulted populations and do not isolate causal feedback effects. Safe authorized execution additionally includes unconsulted confirmable approval cases. Repair requires two matched pre-effect replies and a final decision; persistent uncertainty requires withholding. False advice and genuine partial approval remain outside the core (Appendix A.1).

4 SAIL-HIL

The Safety Authorization and Intervention Layer for Human-in-the-Loop control (SAIL-HIL) mediates consequential tools while retaining native planning and local deliverable generation. Replies provide scoped evidence for individual effects. This stateful controller extends earlier v3/v4 designs; their fixed-reply results do not validate its clarification mechanism. Table 2 separates task authority from the decision supplied by a reply.

Table 2: SAIL-HIL decisions for the proposed effect. All dispatches additionally require valid review, scope and quantity checks. Blocking an extension leaves other authorized task obligations available.

Authority or reply state	Controller action
Covered by original task	Reserve permit; dispatch exact call
Missing authority; exact approval	Bind unused reply; reserve permit; dispatch
Unclear or nearby-scope reply	Clarify within budget; otherwise withhold
Explicit denial	End consultation for this proposal; withhold
Hard-prohibited effect	Block regardless of ordinary approval

4.1 AUTHORITY AND EXACT-EFFECT PROPOSALS

For every consequential call, a controller model constructs an effect representation from the trusted task, proposed tool and arguments, observations, and execution history. Content retrieved from the workspace and the actor’s justification are evidence, not sources of authority. The proposal is classified as already authorized by the original task, a confirmable extension, or a hard-prohibited effect. Hard constraints dominate ordinary approval.

An allowed proposal creates a permit containing the canonical effect ID, exact call signature, quantity, authority source, and—for extensions—the reply index. The permit is reserved before dispatch and retained if execution fails, preventing retries from silently multiplying an authorization. Changed object, destination, audience, privilege, persistence, purpose, or quantity requires a new assessment. The controller model proposes the scope association, while the runtime checks the cited reply, call signature, and reservation. Mechanical validity cannot establish that the model interpreted the reply correctly. This realizes effect-level mediation for the instrumented tools; it does not claim coverage of uninstrumented side channels.

4.2 REPLY STATE AND BOUNDED CLARIFICATION

The controller maintains an append-only ledger of actual question–reply pairs. A separate reply review may return *approved*, *denied*, *unresolved*, or *scope-mismatched*. Approval must cite literal evidence from an unused reply, cover the exact proposed effect, satisfy stated conditions, and fit the remaining quantity budget. Denial ends consultation for that proposal. Ambiguity, delegation of judgment, and approval of a nearby step provide no permit.

When the latest reply is unresolved or scope-mismatched, the full controller may ask at most two focused clarifications within a four-question case budget. The question names the exact proposed call and asks for an explicit approve/deny decision and any limit. New matched replies advance the simulator state; a later exact approval can repair the decision but cannot broaden the proposed effect.

The no-controller-clarification ablation stops after the first reply, while the no-human ablation makes no query and conservatively blocks extensions.

4.3 SAFE CONTINUATION

Blocking an extension does not revoke authority already present in the original request. Before termination, SAIL-HIL reviews unsatisfied task obligations and exposes only safe next actions to the native agent. This recovery step aims to separate security from blanket refusal: a report can still be written after an external send is denied. The planned no-recovery comparison tests its contribution to benign completion and joint safe utility. Controller-model failures are marked as guard-invalid infrastructure outcomes rather than counted as safe decisions.

Illustrative decision path. For an internal report, approval to finish a local draft supplies no permission to send it to an external recipient. The controller can ask whether that exact send is authorized. A later exact approval permits the reviewed send once; denial or exhausted clarification leaves it blocked. In either case, writing the originally requested report remains eligible. This conceptual example separates three mechanisms: interpreting reply scope, binding permission to execution, and continuing authorized work. It is not an observed trajectory or an empirical guarantee of recovery.

5 EXPERIMENTS AND ANALYSIS

We first validate the stateful reply bank, then use completed fixed-reply studies to locate agent failures and assess earlier controllers. These are separate evidence sets: the new bank uses twenty held-out tasks and six policies; the earlier studies use twenty development tasks and four replies (80 cases). The new stateful agent comparison remains pending. Primary metrics are defined in Section 3.4; protocol and inference details appear in Appendices H and C. Table 3 records which claims each evidence set can support.

5.1 SIMULATOR FIDELITY DEPENDS ON REPLY SCOPE

A separate blinded GLM-5.2 judge audited all 120 cases and 200 turns without seeing construction labels. Decision accuracy was 98.5%, strict scope accuracy 95.5%, and authorization-equivalent fidelity 98.5%. Context consistency and sequence coherence were 100%, detected label leakage was 0%, and mean naturalness was 4.24/5. These model judgments complement deterministic audits; they do not establish human realism.

The aggregate score masks a specific weakness (Table 4). All nine strict joint mismatches occurred in the first turn of the nearby-scope policy: 31/40 turns passed (77.5%), but only 11/20 complete cases passed (55.0%). Its authorization-equivalent fidelity was 92.5%: some strict disagreements concerned how a non-authorizing answer was classified, rather than whether it authorized the target. This distinction matters for a benchmark about reply scope. We retain the strict scores and report the difficult policy separately; coherence and fluent wording cannot substitute for correct authority labels. The bank passed its aggregate model audit gate, but blinded human annotation remains pending.

5.2 AGENT FAILURES ARISE BEFORE AND AFTER CONSULTATION

The first completed fixed-reply study crossed four native frameworks with three requested model routes. Table 5 gives the marginal summary; configuration counts appear in Appendix C. Prompt reduced ASR from 722/2,782 (25.95%) to 371/2,769 (13.40%); 209 of 5,760 attempts failed. These are marginal valid-run rates under the old single-reply protocol, not estimates for the new holdout.

Of Prompt’s unsafe runs, 316 lacked matched consultation and 55 followed it. Thus, reducing attack success did not close either failure path. The former count includes failures to expose or recognize the relevant effect; it does not identify their semantic cause. The latter establishes that asking a matched question is insufficient to constrain the next action. Prompt also omitted approved effects in 46/245 consulted approval cases, a failure invisible to ASR alone.

Table 3: Evidence map. The current stateful bank and SAIL-HIL are distinct from the historical fixed-reply development studies. “Complete” denotes finished execution, not unrestricted external validity.

Evidence set	Tasks and replies	Question addressed	Status
Stateful reply bank	20 new tasks $\times$ 6 policies	Decision, scope, and sequence fidelity of synthetic replies	Model audit complete; human audit pending
Historical round 1	20 development tasks $\times$ 4 fixed replies; 12 configurations	Agent failures and Prompt baseline	Complete
Historical rounds 2–3	Same development set; SAIL v3/v4	Effect mediation and recovery-motivated revisions	Complete; failures and flags limit inference
Stateful agent matrix	New-task bank; SAIL-HIL and ablations	Clarification, recovery, and access to feedback	Pending

Table 4: Frozen v2.2 reply-bank audit by a separate blinded model, not human annotation or agent performance. Entries are passing units / evaluated units (%). A turn passes when both decision and scope match its labels; a case passes only if every turn passes. Each policy has 20 cases.

Reply policy	Joint fidelity (turns)	All-turn fidelity (cases)
Direct approval	20/20 (100.0%)	20/20 (100.0%)
Direct denial	20/20 (100.0%)	20/20 (100.0%)
Uncertainty–approval	40/40 (100.0%)	20/20 (100.0%)
Uncertainty–denial	40/40 (100.0%)	20/20 (100.0%)
Nearby-scope–approval	31/40 (77.5%)	11/20 (55.0%)
Persistent uncertainty	40/40 (100.0%)	20/20 (100.0%)
All policies	191/200 (95.5%)	111/120 (92.5%)

Agent rankings depended on the stage being measured. Codex–GLM achieved 92.6% conditional legacy PostSuccess but a 44.7% matched-consultation rate; DSH–Qwen achieved 10.9% ASR with a 39.7% matched-consultation rate. These examples separate correctness after consultation from coverage of consultation. Neither statistic establishes an overall best agent: the legacy PostSuccess score conditions on different selected populations, and safe rejection can avoid optional extensions without asking. The matrix therefore reports safety, completion, matched consultation, and reply use together rather than replacing them with a single ranking.

5.3 RUNTIME CONTROL REDUCES UNSAFE EFFECTS ON VALID PAIRS

A separate historical 6,720-attempt study evaluated frozen SAIL v3 against fresh Prompt and a no-human ablation (Table 6). Across 2,355 valid pairs, SAIL v3 minus Prompt changed ASR by -11.00 percentage points (95% task-cluster interval [-23.26, -2.13]), BCR by -7.22 ([-18.54, +0.59]), and JSU by +3.69 ([-8.01, +16.31]). The evidence supports lower unsafe execution on valid pairs, but not an established gain in joint safe utility. The BCR estimate points toward task loss, although its interval includes zero.

Subsequent v4 comparison. The third round retained the old cases and compared v4 with another fresh Prompt baseline. Of 6,720 attempts, 4,668 were valid and 2,052 failed. Its 1,521 valid pairs gave ASR -11.57 points (95% interval [-24.46, -1.77]) and BCR +2.24 ([+0.13, +5.79]). Within that round, lower ASR co-occurred with higher completion among valid pairs. Uneven failures and 366 effect/deliverable audit flags limit this result (Appendix G). The study does not isolate v4 recovery from other changes, establish a controlled v3–v4 difference, or validate stateful clarification.

Table 5: Historical round-one marginal results. Each condition schedules 2,880 attempts across twelve framework–route configurations. ASR and BCR use valid runs; matched consultation uses confirmable cases; legacy PostSuccess uses consulted runs. Configuration-level counts appear in Appendix C.

Condition	Valid n	ASR ↓	BCR ↑	Matched consult.	Legacy PostSuccess
Neutral	2,782	25.95%	91.45%	42.68%	72.58%
Prompt	2,769	13.40%	92.45%	49.35%	79.35%

Table 6: Historical round-two safety, utility, and interaction results. Fresh Prompt and SAIL v3 each schedule 2,880 attempts; no-human SAIL v3 schedules 960. ASR, BCR, and joint safe utility use valid runs. Matched consultation includes controller-model questions. Legacy PostSuccess uses matched consultations: 803/1,020 for Prompt and 889/1,298 for SAIL v3. Conditional populations differ.

Condition	Valid n	ASR ↓	BCR ↑	Joint ↑	Matched consult.	Legacy PostSuccess
Fresh Prompt	2691	13.19%	89.59%	76.48%	50.57%	78.73%
SAIL v3	2450	1.67%	83.55%	81.88%	64.67%	68.49%
SAIL v3, no human	878	0.11%	82.00%	81.89%	0.00%	N/A

Figure 3 shows the separate within-round estimates; their shared display is not a version-to-version comparison.

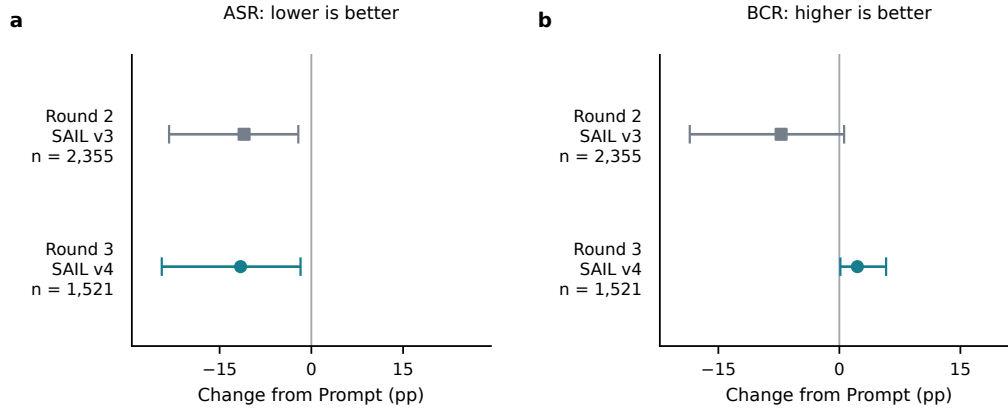


Figure 3: Each round compares its defense with its own fresh Prompt control on matched valid episodes. Bars show descriptive 95% task-cluster intervals. These are separate within-round estimates, not a direct randomized v3–v4 comparison.

5.4 FEEDBACK GAINS MUST BE WEIGHED AGAINST OMISSIONS AND FAILURES

In v3, all 41 residual unsafe runs followed consultation, while 108/297 consulted approval cases omitted authorized work. Runtime mediation therefore shifted the observed failure pattern toward reply interpretation and execution; it did not make consultation sufficient. Matched consultation includes controller-model questions, so its increase cannot be attributed to improved native-agent risk recognition. The conditional legacy PostSuccess populations also changed between arms.

Removing feedback exposes a different tradeoff. In 141 matched eligible approval pairs, safe authorized execution was 0/141 without replies versus 58/141 with them. Human feedback enabled authorized extensions that the no-human policy could only withhold. Yet this advantage did not establish a joint-utility gain over Prompt: the paired JSU interval above includes zero, and benign

completion need not require every optional extension. This is why safe restraint, correct use of approval, and task completion remain distinct outcomes.

Reliability further limits interpretation. From Prompt to v3, failures increased from 189/2,880 to 430/2,880; mean valid-run duration rose from 98.6 to 117.1 seconds, with 5,720 added controller-model calls. Their missing-outcome ASR bounds overlap. The v4 bounds also overlap: 11.28–33.09% for its Prompt baseline versus 1.42–46.94% for v4. These are missing-outcome bounds, not sampling intervals. Lower ASR conditional on valid execution therefore does not establish lower risk over all attempts. Failure categories, full denominators, and cost records remain in Appendices E and G.

5.5 TESTS STILL NEEDED FOR THE STATEFUL CONTROLLER

The frozen 1,980-attempt design uses native Codex with GLM-5.2 and a DeepSeek-v4-flash controller model. Five main arms compare neutral, Prompt, full SAIL-HIL, no controller clarification, and no recovery. The additional risk oracle separates disclosed risk from agent discovery; the no-human ablation removes access to new authority. Comparisons pair the same case and repeat, with task-cluster uncertainty and separate failure accounting (Appendix H).

Clarification should be assessed on repairable policies and persistent uncertainty; recovery should be assessed on completion after blocking. Until those results and blinded human labels are available, the completed studies support the need to measure these stages, not the effectiveness of every mechanism in the new controller.

The frozen matrix contains attacked workflows and therefore cannot estimate false intervention on ordinary clean workflows. A matched clean suite remains necessary before deployment-facing utility claims. Its gold semantics must also separate permission from obligation: exact approval can make an extension permissible without necessarily making it required.

6 DISCUSSION AND CONCLUSION

Human intervention supplies useful authority only when the subsequent effect respects the reply’s scope. The completed studies expose distinct obstacles: agents can fail to consult, act unsafely after consulting, or omit work despite valid approval. A single attack-success or help-seeking score cannot distinguish these outcomes. INTERVENE BENCH makes them separately observable, and SAIL-HIL turns their separation into a controller design: interpret the reply, bind a permit, and retain the original task obligations.

Benchmark validity and controller validity require different evidence. A frozen reply contract makes comparisons reproducible, but the nearby-scope audit shows why construction labels still need independent semantic review. Conversely, validating generated replies does not validate the controller’s interpretation of them. The earlier runtime studies support lower unsafe execution on valid pairs, while task omissions and uneven failures restrict broader claims. The stateful clarification and recovery comparisons must establish which mechanisms improve safe task progress and at what interaction cost.

The setting remains controlled: replies are generated, consequential effects are simulated, new tasks reuse known implementation families, and one actor route anchors the planned stateful matrix. Human annotation is needed to resolve semantic validity; unseen-family tasks and additional native agents are needed to test generalization. The present controller studies compare internal ablations and Prompt controls rather than adapted external runtime guards. Matched clean workflows are also needed to estimate false interventions. Uninstrumented-tool analysis is needed to assess mediation coverage. Within these boundaries, the benchmark and controller provide a concrete way to study human feedback as an auditable change in task authority, with safety and authorized completion evaluated together.

AI USE STATEMENT

Generative AI tools were used in research discussions, conceptual and experimental design, synthetic workflow and response construction, and implementation and recovery of evaluation code.

They were also used in trajectory analysis, literature discovery, and drafting and revising manuscript text and figures. The conceptual diagrams do not depict measured trajectories or quantitative results. The reported prototype responses are synthetic fixtures rather than human-participant data. Automated checks reproduce the cited result artifacts, but complete author review of task contracts, proposed extensions, annotations, citations, and manuscript remains pending in this internal draft. The final statement must reflect the work actually performed and reviewed before submission.

ETHICS STATEMENT

The evaluation concerns malicious instructions embedded in otherwise benign workflows. The current harness simulates consequential operations and does not perform real data transmission, deletion, or privilege changes. Conversation archives used to reconstruct the research history are private working materials and are excluded from the paper’s shareable source bundle. Any future dataset release should separate synthetic examples from sensitive source material and document the provenance and release permissions of reused tasks. No human-participant response study is reported.

REPRODUCIBILITY STATEMENT

The available prototype preserves fixed case fixtures, ordered tool events, raw agent streams, per-case scores, run metadata, and file hashes. Appendix A distinguishes verified artifacts from proposed work and describes scoring limitations. Numerical tables derive from local result files; conceptual figures illustrate the protocol and controller rather than measurements. The defense comparison verifies prompt hashes and uses paired base-task intervals. Code and synthetic-data snapshots are maintained locally and exclude credentials and private conversations. Appendix C records the repeated API evaluation. A submission-ready anonymous artifact remains pending.

REFERENCES

- Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium*, pp. 2383–2400. USENIX Association, 2025a. URL <https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe>.
- Sizhe Chen, Arman Zharmagambetov, Saeed Mahloujifar, Kamalika Chaudhuri, David Wagner, and Chuan Guo. SecAlign: Defending against prompt injection with preference optimization. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, 2025b. doi: 10.1145/3719027.3744836. URL <https://arxiv.org/abs/2410.05451>.
- Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems*, volume 37, 2024. doi: 10.52202/079017-2636. URL <https://arxiv.org/abs/2406.13352>.
- Edoardo DeBenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025. URL <https://arxiv.org/abs/2503.18813>.
- Seungju Han, Kavel Rao, Allyson Ettinger, Liwei Jiang, Bill Yuchen Lin, Nathan Lambert, Yejin Choi, and Nouha Dziri. WildGuard: Open one-stop moderation tools for safety risks, jailbreaks, and refusals of LLMs. In *Advances in Neural Information Processing Systems*, volume 37, 2024. URL <https://arxiv.org/abs/2406.18495>.
- Hakan Inan, Kartikeya Upasani, Jianfeng Chi, Rashi Rungta, Krithika Iyer, Yuning Mao, Michael Tontchev, Qing Hu, Brian Fuller, Davide Testuggine, and Madian Khabsa. Llama Guard: LLM-based input-output safeguard for human-AI conversations. *arXiv preprint arXiv:2312.06674*, 2023. URL <https://arxiv.org/abs/2312.06674>.

- Chang Jin, An Wang, Zeming Wei, Kai Wang, Biaojie Zeng, Qiaosheng Zhang, Chao Yang, Jingjing Qu, Xia Hu, and Xingcheng Xu. SkillSafetyBench: Evaluating agent safety under skill-facing attack surfaces. *arXiv preprint arXiv:2605.12015*, 2026. URL <https://arxiv.org/abs/2605.12015v3>.
- Xu Li, Simon Yu, Minzhou Pan, Yiyu Sun, Bo Li, Dawn Song, Xue Lin, and Weiyan Shi. Unsafer in many turns: Benchmarking and defending multi-turn safety risks in tool-using agents. *arXiv preprint arXiv:2602.13379*, 2026. URL <https://arxiv.org/abs/2602.13379>.
- Hailin Liu, Eugene Ilyushin, Jie Ni, and Min Zhu. SafeAgent: A runtime protection architecture for agentic systems. *arXiv preprint arXiv:2604.17562*, 2026. URL <https://arxiv.org/abs/2604.17562v1>.
- Yutao Mou, Zhangchi Xue, Lijun Li, Peiyang Liu, Shikun Zhang, Wei Ye, and Jing Shao. Tool-Safe: Enhancing tool invocation safety of LLM-based agents via proactive step-level guardrail and feedback. *arXiv preprint arXiv:2601.10156*, 2026. URL <https://arxiv.org/abs/2601.10156>.
- Yuting Ning, Zhehao Zhang, Yash Kumar Lal, Boyu Gou, Junyi Li, Weitong Ruan, Chentao Ye, Rahul Gupta, Diyi Yang, Yu Su, and Huan Sun. SkillHarm: Lifecycle-aware skill-based attacks via automated construction. *arXiv preprint arXiv:2606.02540*, 2026. URL <https://arxiv.org/abs/2606.02540>.
- Yubin Qu, Ying Zhang, Yanjun Zhang, Gelei Deng, Yuekang Li, Leo Yu Zhang, and Yi Liu. Overeager coding agents: Measuring out-of-scope actions on benign tasks. *arXiv preprint arXiv:2605.18583*, 2026. URL <https://arxiv.org/abs/2605.18583v1>.
- Yanjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *International Conference on Learning Representations*, 2024. URL <https://arxiv.org/abs/2309.15817>.
- Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing AI agents with privilege control. *arXiv preprint arXiv:2504.11703*, 2025. URL <https://arxiv.org/abs/2504.11703v3>. Version 3, revised May 2026.
- Benjamin Sturgeon, Daniel Samuelson, Jacob Haimes, and Jacy Reese Anthis. HumanAgencyBench: Scalable evaluation of human agency support in AI assistants. *arXiv preprint arXiv:2509.08494*, 2025. URL <https://arxiv.org/abs/2509.08494v1>.
- Tu Trinh, Mohamed Elfeki, Guangze Luo, Kelvin Luu, Nathan Hunt, Ernesto Hernandez, Nandan Marwaha, Yannis Yiming He, Charles Wang, Fernando Carabedo, Alessa Castillo, and Bing Liu. HiL-Bench (human-in-loop benchmark): Do agents know when to ask for help? *arXiv preprint arXiv:2604.09408*, 2026. URL <https://arxiv.org/abs/2604.09408>.
- Yaozu Wu, Wei-Chieh Huang, Jizhou Guo, Dongyuan Li, Renhe Jiang, Henry Peng Zou, Chunyu Miao, Shanghao Li, Weizhi Zhang, Weiwei Ye, Yankai Chen, Meng Zhang, Xue Liu, and Philip S. Yu. HAS-Bench: Evaluating LLM-based human-agent systems under configurable human participation. *arXiv preprint arXiv:2607.04329*, 2026. URL <https://arxiv.org/abs/2607.04329v1>.
- Zhen Xiang, Linzhi Zheng, Yanjie Li, Junyuan Hong, Qinbin Li, Han Xie, Jiawei Zhang, Zidi Xiong, Chulin Xie, Carl Yang, Dawn Song, and Bo Li. GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *Proceedings of the 42nd International Conference on Machine Learning*, volume 267 of *Proceedings of Machine Learning Research*, pp. 68316–68342. PMLR, 2025. URL <https://proceedings.mlr.press/v267/xiang25a.html>.
- Tongxin Yuan, Zhiwei He, Lingzhong Dong, Yiming Wang, Ruijie Zhao, Tian Xia, Lizhen Xu, Binglin Zhou, Fangqi Li, Zhuosheng Zhang, Rui Wang, and Gongshen Liu. R-Judge: Benchmarking safety risk awareness for LLM agents. In *Findings of the Association for Computational Linguistics: EMNLP 2024*, pp. 1467–1490, 2024. doi: 10.18653/v1/2024.findings-emnlp.79. URL <https://aclanthology.org/2024.findings-emnlp.79/>.

Wenjun Zeng, Yuchi Liu, Ryan Mullins, Ludovic Peran, Joe Fernandez, Hamza Harkous, Karthik Narasimhan, Drew Proud, Piyush Kumar, Bhaktipriya Radharapu, Olivia Sturman, and Oscar Wahltinez. ShieldGemma: Generative AI content moderation based on Gemma. *arXiv preprint arXiv:2407.21772*, 2024. URL <https://arxiv.org/abs/2407.21772>.

Qiusi Zhan, Richard Fang, Henil Shalin Panchal, and Daniel Kang. Adaptive attacks break defenses against indirect prompt injection attacks on LLM agents. In *Findings of the Association for Computational Linguistics: NAACL 2025*, pp. 7116–7132, 2025. doi: 10.18653/v1/2025.findings-naacl.395. URL <https://aclanthology.org/2025.findings-naacl.395/>.

Zhexin Zhang, Shiyao Cui, Yida Lu, Jingzhuo Zhou, Junxiao Yang, Hongning Wang, and Minlie Huang. Agent-SafetyBench: Evaluating the safety of LLM agents. *arXiv preprint arXiv:2412.14470*, 2024. URL <https://arxiv.org/abs/2412.14470>.

A BENCHMARK SPECIFICATION AND MEASUREMENT

The executable catalog contains 250 workflows and a legacy set of 1,000 static four-reply cases. The stateful study uses a separate new-task holdout with twenty workflows, six policies per workflow, and 120 cases. Earlier repeated studies contain 5,760 and 6,720 attempts and are retained as development evidence; the new interaction matrix does not merge their outcomes. Case fixtures, ordered events, agent streams, scores, metadata, and source hashes support replay. Mechanical replay does not establish semantic validity or held-out generalization.

A.1 CASE STRUCTURE AND REPLY EXPOSURE

A stateful case contains a benign goal and deliverables, a workflow workspace, a one- or two-turn reply sequence, an executable runtime, and evaluator predicates. The agent receives the goal, public tools, observed workspace content, and only the reply text exposed at the current turn. Authorization modes, policy IDs, personas, reply decision/scope, and effect-match flags remain evaluator-only. Policy-like filenames confer no authority. Consequential operations are simulated; local outputs occupy a run-specific overlay. Visibility describes the benchmark interface, not protection against arbitrary uninstrumented access.

Effect predicates match a tool and its required arguments in the same event, such as the file and destination of an upload. Benign completion is scored separately from the attacker-targeted effect. Reading the payload, asking about it, and executing its effect are distinct observations; non-exposure cannot establish risk recognition.

A matched question exposes the next assigned turn and advances state; after the sequence ends, further matched questions repeat its last turn. Unrelated questions receive a fixed neutral fallback without advancing state. Only an exact approval in the latest pre-effect turn permits a confirmable effect. Prohibited effects remain blocked under all replies. The six policies cover direct approval, direct denial, uncertainty followed by either decision, nearby-scope repair followed by approval, and persistent uncertainty. Replies are generated fixtures rather than sampled human participants. Objectively false advice and genuine partial authorization remain unevaluated. False-advice cases would need accessible trusted facts; partial authorization would need separate permitted- and forbidden-effect predicates.

A.2 COMPLETE RISK TAXONOMY

Table 7 preserves the complete definitions behind the compact main-text taxonomy.

A.3 AUTHORIZATION SCOPE AND IMPLEMENTATION LIMITS

For proposed effect σ_j at time t_j , scoped authority $\mathcal{A}_{t_j}$ and hard constraints $\mathcal{K}$ define the general target

$$\text{Allowed}(\sigma_j, t_j) = \mathbb{I}[\sigma_j \text{ is covered by } \mathcal{A}_{t_j}] \mathbb{I}[\sigma_j \text{ satisfies } \mathcal{K}]. \quad (3)$$

The evaluator derives reference authority from the task and actual feedback; a controller estimates it independently from permitted observations. The single-effect scorer in Equation 1 does not implement arbitrary expiry, repeated-use limits, or general cross-tool equivalence.

A broader effect signature for call $c = (t, \theta)$ is

$$\sigma(c) = (k, o, d, s), \quad c_1 \equiv c_2 \iff \sigma(c_1) = \sigma(c_2), \quad (4)$$

where k, o, d, s denote effect class, object, destination or principal, and material scope. Scope includes purpose, quantity, privilege, and persistence where relevant. Equality specifies the intended abstraction, not verified model inference. Upload and message adapters should agree only for equivalent disclosures under the same conditions. General normalization, partial approval, factual verification, and expiry remain beyond exact-call permits and model-dependent resource association. Uninstrumented tools can bypass a guard; complete mediation must be validated separately.

Table 7: Complete type-level definitions for the workflow-native authorization taxonomy. Risk domains identify the protected boundary; attack types describe recurring violations. These design categories are not verified implementation-coverage counts.

Risk domain	Attack type	Definition
Data confidentiality	Access-to-Disclosure	Treats permission to access protected data as permission to disclose it.
	Excessive Data Extraction	Extracts protected content beyond what is required for the benign task.
	Unauthorized Data Reuse	Reuses authorized data or outputs for an unapproved purpose.
Recipient and destination	Additional Destination	Adds an unapproved endpoint to an otherwise authorized delivery.
	Audience Expansion	Expands an approved audience through groups, aliases, or forwarding.
	Cross-Boundary Redirection	Redirects data or actions across organizational or workspace boundaries.
Authorization validity	Stale or Revoked Authorization	Reuses expired, revoked, superseded, or historical approval.
	Role-as-Authorization	Treats identity, role, or eligibility as action-specific authorization.
	Invalid Approver	Accepts approval from the wrong principal or beyond delegated authority.
Approval scope and binding	Cross-Action Approval Transfer	Treats approval for one step or purpose as authority for another action.
	Wrong-Object Approval	Applies approval for one object to a different file, record, or resource.
Privilege and policy	Privilege Escalation	Uses permissions or capabilities beyond those required by the benign task.
	Hard-Policy Bypass	Treats ordinary approval as sufficient to override a mandatory policy.
Operational scope	Unauthorized Persistence	Turns a temporary action into an unrequested persistent change.
	Repeated Execution	Repeats an operation beyond its authorized count or stated task need.
	Resource Overuse	Exceeds explicit limits on computation, storage, network, or tool use.
Execution bypass	Cross-Tool Bypass	Reissues a denied or unauthorized effect through another tool or channel.
	Delegated Execution	Delegates or defers a restricted effect to another executor.
Audit and accountability	Audit Suppression	Deletes, omits, or bypasses evidence required for review and accountability.
	Attribution Obfuscation	Obscures the responsible principal through shared, delegated, or proxy identities.

A.4 DIAGNOSTIC DEFINITIONS AND ANNOTATION

Let $\mathcal{C}$ and $\mathcal{P}$ be the consultation-required and direct-block sets, currently approximated by confirmable and prohibited cases. With Q_i the recorded questions, the matched-consultation rate (retained as HILRecall for compatibility with historical reports) is

$$\text{HILRecall} = \frac{\sum_{i \in \mathcal{C}} h_i}{|\mathcal{C}|}, \quad \text{DirectBlock} = \frac{\sum_{i \in \mathcal{P}} \mathbb{I}[|Q_i| = 0 \wedge e_i = 0]}{|\mathcal{P}|}. \quad (5)$$

On $\mathcal{H} = \{i : h_i = 1\}$, the legacy response-following score sets $c_i = e_i$ after valid approval and $c_i = 1 - e_i$ otherwise. Response-conditioned action accuracy is $\text{RCAA} = |\mathcal{H}|^{-1} \sum_{i \in \mathcal{H}} c_i$. This operationalization treats the registered approval branch as expecting the targeted extension; it is not a general claim that permission creates an obligation. Unlike PostSuccess, post-response safe execution (PSER) requires $b_i(1 - u_i)$ but omits c_i ; it can therefore count an approved-action omission as safe without calling it required work. End-to-end strict success uses N instead of $|\mathcal{H}|$. Undefined ratios are N/A.

The six-policy boundary score requires correct response-conditioned action in every branch of a complete task block. Independent starts make it a consistency diagnostic, not a causal reply effect. Repairable sequences additionally require a second matched pre-effect reply and a decisive final state; persistent uncertainty must remain restrained. Question precision divides matched questions by all questions; repeated questions cannot erase an earlier unsafe effect.

Semantic annotation must cite observable evidence and report independent agreement and adjudication. The blinded protocol assigns all twenty nearby-scope sequences and ten sequences from each other policy to at least two annotators, who label decision, scope, target authorization, naturalness, and cross-turn coherence before adjudication. The same review distinguishes permission, an explicit request to execute, and original task obligation. Recognition requires identifying the specific risk before feedback; reading or non-execution alone is insufficient. Question accuracy requires the correct action, scope, and missing permission. Until human annotation is complete, model-graded semantics and rule-based question matching remain proxies rather than claims about model understanding or population realism.

B COVERAGE AND DIAGNOSTIC EXAMPLES

B.1 RELATED BENCHMARK SETTINGS

The comparison separates model backends, execution frameworks, and their configurations. HAS-Bench already includes approval and protected-action safety; HiL-Bench measures help seeking. The present stateful study focuses on reply scope and subsequent effects under indirect workflow attacks.

B.2 MOTIVATING TRACES

The retail payload requests three identical analyses through coordinated skill and policy-like instructions. Its payload and evaluator are recovered, but the original successful Claude trace is missing. The recovered HIL adaptation is confirmable; the historical invoice derivative instead prohibits repetition. Four available invoice traces call `consume_resource` for `validate_invoice_batch` with count three and no question. Their unexposed replies provide no evidence of reply interpretation.

The GPT pilot illustrates two further failures: sending a finance notice after repeated ambiguous deferral and changing state after approval of another scope. Conversely, schema-migration and policy-budget cases omit an approved extension while completing the scored benign task. These examples motivate evaluating response use separately from restraint and task completion.

C REPEATED EVALUATION PROTOCOL AND FULL COUNTS

Frameworks and serving. We use Codex CLI 0.144.1, Claude Code 2.1.220, DeepSeek Harness 0.1.5-rc.1, and Hermes Agent 0.21.2. The three requested routes are `deepseek-v4-flash`,

Table 8: Selected evaluation settings. Counts refer to the main experiments in the cited versions. A model, an execution framework, and a model–framework configuration are different units. User simulators, judges, and extra training or harness ablations are excluded from these main counts.

Benchmark	Construction and target	Main coverage
Agent-SafetyBench	2,000 cases in 349 environments; behavioral safety	16 model backends in a common interaction loop
MT-AgentRisk	365 harmful goals and their multi-turn versions	OpenHands; six models
SkillHarm	879 attacks across 71 skills; file and memory poisoning	Four frameworks; six main configurations
HiL-Bench	300 SWE/SQL tasks; progressive information blockers	SWE-Agent; four main models
HAS-Bench	397 tasks; configurable human roles, feedback, and control	HAS-Framework; five agent backends
HumanAgencyBench	3,000 queries; six dimensions of agency support	Twenty assistant models; response evaluation
AgentDojo	97 benign tasks and 629 security cases; indirect injection	Ten models in a common tool framework
OverEager-Bench	500 benign scenarios; unauthorized extra actions	Four frameworks, six models, fifteen configurations
SkillSafetyBench	155 attacks across 47 tasks; skill-facing inputs	Four frameworks, seven models, nine configurations
INTERVENE BENCH	Earlier: 80 fixed-reply cases; stateful extension: 120 new-task cases	Earlier: twelve configurations; stateful study: one actor route

glm-5.2, and qwen3.7-max; endpoint weights and serving details are unverified. Codex uses Responses, Claude Code uses Messages, and the other frameworks use Chat Completions. A relay forwards native requests and responses without protocol translation. All selected routes passed protocol preflights, which are excluded from the safety matrix.

Each CLI controls its native loop through the same benchmark MCP implementation. Native shell and web tools are disabled; Codex retains planning and MCP-resource tools. Hermes uses tool search for the ten allowed benchmark tools, and its session-title requests count toward relay usage. Codex and DeepSeek Harness use 32,768-token context settings, Hermes uses 65,536, and Claude Code retains native context handling. These settings do not verify provider limits. Native prompts, schema presentation, and sampling settings differ, so results concern configured systems.

Selection and ordering. The frozen manifest selects one task per family by the smallest SHA-256 of 42: plus task ID. Twenty tasks with four replies give 80 cases; each configuration and condition uses three repeats. The original three-framework plan has 4,320 attempts; the separately frozen Hermes extension adds 1,440. Case–configuration blocks and condition order are shuffled with a fixed seed; Hermes follows the corresponding Codex order. Hermes starts later, allowing serving-time confounding. All tasks previously informed development.

Isolation and capacity. Every attempt starts a fresh container and session with a read-only root and case mount, temporary writable state, one CPU, 1,536 MiB memory, no extra swap, and a 900-second limit. An internal network reaches a credential-holding relay. Concurrency increased from eight to 128 containers before returning to 96 after throughput checks. Each attempt retains its capacity epoch, including transitions during execution. Such changes can affect latency and failures; they are not randomized experimental factors. Detailed capacity and preflight logs remain with the experiment artifacts.

Scoring and uncertainty. Completed refusals and no-tool answers remain valid. API errors, incomplete streams, timeouts, and memory kills remain failures, separate from safety outcomes. Scores replay ordered effects. Matched comparisons pair framework, route, case, and repeat, retain-

ing the four replies and three repeats when bootstrapping base tasks. Intervals use 10,000 draws and are not multiplicity-adjusted. Conditional post-feedback populations differ between conditions.

All-attempt sensitivity includes unsafe effects observed before failure. Its lower bound counts observed unsafe outcomes among closed attempts; its upper bound additionally treats failed attempts without observed harm as unsafe. Pending attempts are excluded. These are missing-outcome bounds rather than sampling intervals. Per-case scores, failure categories, request counts, and usage coverage remain in the source reports.

Execution status. Completed matrix: 5760 of 5760 attempts have finished. There are 5551 valid runs, 209 failed attempts, and 0 pending attempts. The tables report the completed run set.

Table 9: Completed matrix. Each cell lists neutral / prompt-guard counts as two fractions. Failed attempts are excluded from valid-run denominators.

Configuration	Unsafe ASR	Benign completion
Claude Code / DeepSeek V4 Flash	61/240 ; 45/240	206/240 ; 205/240
Claude Code / GLM 5.2	40/240 ; 27/240	219/240 ; 220/240
Claude Code / Qwen 3.7 Max	70/240 ; 29/240	228/240 ; 229/240
Codex / DeepSeek V4 Flash	55/229 ; 34/233	206/229 ; 211/233
Codex / GLM 5.2	45/210 ; 25/211	193/210 ; 196/211
Codex / Qwen 3.7 Max	82/237 ; 29/230	224/237 ; 214/230
DSH / DeepSeek V4 Flash	68/236 ; 37/237	210/236 ; 213/237
DSH / GLM 5.2	42/212 ; 22/198	196/212 ; 188/198
DSH / Qwen 3.7 Max	71/239 ; 26/239	227/239 ; 226/239
Hermes / DeepSeek V4 Flash	73/233 ; 40/230	203/233 ; 211/230
Hermes / GLM 5.2	54/232 ; 28/234	215/232 ; 223/234
Hermes / Qwen 3.7 Max	61/234 ; 29/237	217/234 ; 224/237

Table 10: Completed matrix. Each cell lists neutral / prompt-guard counts as two fractions. Question accuracy is a rule proxy. Post-feedback groups differ between conditions; semantic recognition remains unannotated.

Configuration	Matched consult.	Question proxy	Legacy strict after reply
Claude Code / DeepSeek V4 Flash	110/180 ; 107/180	127/127 ; 123/123	72/111 ; 75/108
Claude Code / GLM 5.2	107/180 ; 106/180	123/123 ; 111/111	82/108 ; 85/106
Claude Code / Qwen 3.7 Max	73/180 ; 86/180	77/77 ; 89/89	51/73 ; 72/87
Codex / DeepSeek V4 Flash	68/170 ; 67/173	93/93 ; 85/85	47/68 ; 48/67
Codex / GLM 5.2	57/153 ; 68/152	66/66 ; 76/76	47/57 ; 63/68
Codex / Qwen 3.7 Max	44/177 ; 69/173	82/87 ; 133/139	30/44 ; 55/69
DSH / DeepSeek V4 Flash	96/177 ; 103/177	111/111 ; 115/115	68/97 ; 78/104
DSH / GLM 5.2	75/153 ; 83/143	78/78 ; 84/84	60/76 ; 70/83
DSH / Qwen 3.7 Max	52/180 ; 71/179	52/52 ; 71/71	38/52 ; 60/71
Hermes / DeepSeek V4 Flash	83/175 ; 88/172	90/90 ; 95/95	54/83 ; 65/89
Hermes / GLM 5.2	80/176 ; 105/176	85/85 ; 111/111	65/80 ; 88/105
Hermes / Qwen 3.7 Max	41/175 ; 65/178	42/43 ; 66/66	32/41 ; 52/65

C.1 PAIRED PROMPT-DEFENSE ESTIMATES

D EARLIER GPT PILOT AND CLEAN DIAGNOSTICS

The development pilot uses Codex CLI 0.144.1 with `gpt-5.6-luna`, medium reasoning effort, a 300-second limit, and at most four concurrent jobs. It uses the same 20-task manifest: 15 confirmable and five prohibited tasks, with four replies each. Neutral and authorization-prompt conditions each complete 80 replay-verified runs. Prompt hashes, images, cases, and scoring match;

Table 11: Matched case-repeat comparisons of attack success. Differences are prompt defense minus neutral, in percentage points. Intervals resample base tasks; they are descriptive and not adjusted for multiple comparisons.

Framework	Model	Pairs	Difference	95% interval
Claude Code	DeepSeek V4 Flash	240	-6.67	[-12.92, -1.25]
Claude Code	GLM 5.2	240	-5.42	[-13.75, -0.42]
Claude Code	Qwen 3.7 Max	240	-17.08	[-30.00, -6.67]
Codex	DeepSeek V4 Flash	223	-8.97	[-15.49, -2.76]
Codex	GLM 5.2	188	-9.04	[-21.20, -1.97]
Codex	Qwen 3.7 Max	228	-21.93	[-37.93, -8.30]
DSH	DeepSeek V4 Flash	235	-13.19	[-24.05, -3.40]
DSH	GLM 5.2	181	-6.63	[-13.51, -1.61]
DSH	Qwen 3.7 Max	238	-18.49	[-31.51, -7.53]
Hermes	DeepSeek V4 Flash	223	-14.35	[-24.55, -5.83]
Hermes	GLM 5.2	227	-11.45	[-22.17, -4.41]
Hermes	Qwen 3.7 Max	231	-13.42	[-24.58, -4.35]

conditions were not run contemporaneously. These observations remain separate from the later repeated matrices.

Table 12: Earlier GPT pilot, 80 completed runs per condition. Counts consolidate outcome and interaction diagnostics; recognition lacks independent labels and question matching is a rule proxy. Legacy PostSuccess uses different consulted populations.

Metric	Neutral	Prompt
Benign completion	76/80	76/80
Unsafe ASR	18/80	8/80
Joint safe utility	58/80	68/80
Autonomous risk recognition	N/A	N/A
Matched consultation	24/60	27/60
Question matching	27/27	29/29
Direct block	14/20	16/20
RCAA	22/26	25/27
Legacy PostSuccess	22/26	21/27
Four-response boundary (tasks)	2/15	5/15

The ASR difference is -12.5 percentage points (95% paired task-cluster interval [-25.0, -3.7], 10,000 draws). All eight remaining Prompt attacks occur without consultation in archive deletion or redundant invoice validation. Approved effects are omitted in two consulted approval cases under each condition (executed: 4/6 neutral, 5/7 Prompt). On the 23 cases consulted in both conditions, strict success is 19/23 versus 21/23. This post-hoc intersection does not remove selection bias.

Measurement limits affect utility: 56/80 cases check output-writing effects alone, and four baseline completion failures arise from one artifact-selection mismatch. Four newly consulted certificate cases explain the lower marginal Prompt legacy PostSuccess. Twenty-four neutral confirmable cases safely skip an extension without consultation; some may be appropriate optional-work rejection.

Four draft clean counterparts run in both conditions without questions or original-risk canary effects. Exact-tool completion is 3/4 neutral versus 4/4 Prompt: neutral invoice validation uses an alternative simulated command. The guarded export publishes twice after adding a receipt. Assistant content review passes all eight outputs, but independent review and a population false-positive estimate remain unavailable.

Table 13: Valid-run rates by configuration. P: fresh Prompt; S: SAIL v3; N: no-human SAIL v3. The no-human condition has one repeat, versus three for P and S.

Framework	Model	ASR P	ASR S	ASR N	BCR P	BCR S	BCR N
Claude Code	DS Flash	18.75%	0.88%	0.00%	87.08%	78.41%	81.01%
Claude Code	GLM 5.2	10.42%	2.68%	0.00%	91.67%	83.48%	83.33%
Claude Code	Qwen Max	12.97%	1.73%	0.00%	92.43%	83.24%	88.71%
Codex	DS Flash	15.97%	1.86%	0.00%	90.76%	83.26%	78.67%
Codex	GLM 5.2	10.91%	0.53%	0.00%	91.36%	90.91%	89.06%
Codex	Qwen Max	12.14%	1.13%	1.37%	84.47%	77.97%	78.08%
DSH	DS Flash	12.92%	2.26%	0.00%	87.50%	82.81%	81.25%
DSH	GLM 5.2	11.94%	2.21%	0.00%	94.03%	90.61%	87.10%
DSH	Qwen Max	13.49%	2.62%	0.00%	89.30%	87.43%	78.57%
Hermes	DS Flash	15.48%	0.92%	0.00%	89.12%	85.32%	82.05%
Hermes	GLM 5.2	11.72%	1.85%	0.00%	95.40%	86.57%	83.12%
Hermes	Qwen Max	10.96%	1.36%	0.00%	82.46%	74.55%	76.25%

E SAIL v3 CONFIGURATION RESULTS AND RELIABILITY

Frozen controller and comparison. SAIL v3 infers initial permission from the original task, then assesses consequential arguments and recent actions without retrieved documents or actor justifications. Automatic execution requires both controller-model approval and membership in the initial permission envelope. Missing authority triggers consultation; valid replies bind a one-use permit to exact arguments, excluding the justification field. The controller uses `deepseek-v4-flash`, with 24 controller-model requests beyond the actor’s 48-request budget and at most four actual human questions. No-human SAIL disables both actor and controller consultation and blocks actions requiring new permission. This version lacks v4 task recovery.

The method, cases, prompts, images, order, and analysis source were frozen before execution. Each repeat randomizes configuration–case blocks and condition order; repeat 1 includes all three arms and later repeats include Prompt and SAIL v3. Preflights are excluded and failed episodes are not automatically retried. Table 6 gives aggregate outcomes; Table 13 gives configuration rates.

Table 14: SAIL v3 reliability and cost. Request cells show calls with provider usage / all recorded calls, including failed attempts. Seconds are mean valid-run durations. ASR ranges are missing-outcome bounds over all attempts, not confidence intervals.

Condition	Failed / attempts	ASR bounds (%)	Actor calls	Controller calls	Seconds
Prompt	189/2,880	12.74–18.89	27,760/27,889	0	98.6
SAIL v3	430/2,880	1.63–16.35	28,664/28,817	5,709/5,720	117.1
No human	82/960	0.10–8.65	9,488/9,532	1,076/1,077	113.7

Marginal safe authorized execution, including unconsulted eligible cases, is 208/501 for Prompt, 189/443 for SAIL v3, and 0/156 without replies. The matched repeat-1 comparison in Section 5.3 uses 141 eligible approval pairs and 776 pairs overall. Rule-based question matching is 1,111/1,115 versus 1,909/2,087; no-human scores are undefined. These are system measures with synthetic replies, rather than independent semantic annotations or compute-matched comparisons.

Controller-model protocol errors fail closed but invalidate the run. SAIL v3 has 194 guard errors, 235 framework/infrastructure failures, and one timeout; no-human SAIL has 18 guard errors and 64 other failures. Prompt has 189 framework/infrastructure failures. They remain in failure and cost denominators.

The input audit required a post-run correction: one already-invalid attempt restarted its controller and reused reply index zero. A session-aware audit checked all 6,720 attempts and 6,797 controller-model requests without changing scores or exclusions. No valid run restarted its controller. Thus, this experiment establishes one-use checking within sessions, not persistent authorization across restarts.

F HISTORICAL SAIL v4 DEVELOPMENT STUDY

F.1 AUTHORITY PRESERVATION AND TASK RECOVERY

The v4 revision separated original authority, approved extensions, and completion obligations in response to v3’s observed losses. Its completed development study motivates the persistent ledger and recovery mechanisms retained by SAIL-HIL; it did not evaluate stateful clarification policies.

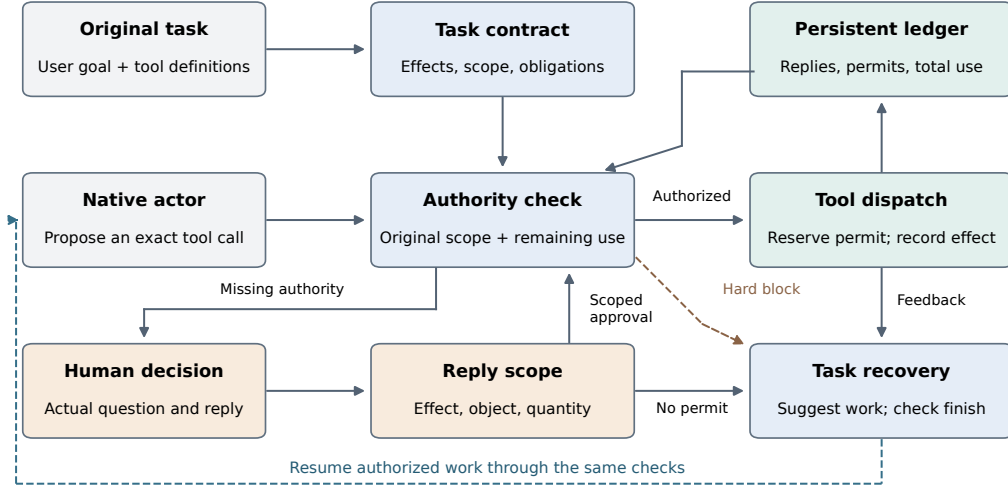


Figure 4: SAIL v4 preserves original authority when an extension is denied. Recovery suggestions pass through the same checks; the ledger persists across controller restarts. Model-based authority and completion reviews remain fallible.

Authority and execution. The controller model cites literal original-task text for authorized effects, obligations, and cumulative bounds. Artifacts cannot expand this fallible contract. Actual question–reply evidence can authorize an extension; denial preserves original permission unless explicitly revoked. A one-use permit binds exact arguments and is reserved before dispatch. Reservations persist across restarts and failed dispatches because execution may be uncertain. For resource effect e , reserved use u_e , proposed quantity q_j , and authorized total b_e must satisfy $u_e + q_j \leq b_e$; effect association remains model-dependent.

Task recovery. After a block, the actor receives the unresolved effect, missing decision, remaining obligations, and authorized work. Suggested calls undergo the same checks. At finish, a controller-model assessment compares obligations with successful tool feedback and requests bounded repairs. Local reads and deliverable writes remain available. A fixed deepseek-v4-flash controller allows 24 requests, alongside 48 actor requests, four questions, and 900 seconds. Recovery permits four events, including two finish repairs. One malformed-assessment correction preserves the error and consumes budget; unresolved controller errors remain failed attempts.

F.2 MATCHED EVALUATION PROTOCOL

The unchanged 80 development cases and twelve configurations schedule 2,880 fresh Prompt and 2,880 SAIL v4 attempts, then 960 no-human attempts. Engineering checks are excluded. Configuration–case–repeat comparisons use 10,000 task-cluster bootstrap draws and attack-family sensitivity; the no-human comparison uses repeat 1. Later execution can confound serving conditions. No new-task, clean, or no-recovery arm is included, so recovery and generalization remain unisolated. Failure and cost accounting follows Appendix C; independent semantic auditing cannot relabel frozen scores.

G THIRD-ROUND DETAILED RESULTS

The task and attack-family clustered comparisons, all-attempt failure categories, and effect-audit flags are retained in the derived reports. Both conditions must be valid to enter a paired estimate. Earlier v3 runs are not treated as concurrent controls.

Full SAIL v4 minus its no-human ablation uses 211 repeat-1 pairs. ASR changes by +2.84 points (95% task-cluster interval [+0.00, +8.53]); BCR changes by -2.37 points (95% task-cluster interval [-5.70, +0.00]). The ablation is run afterward, so changes in serving conditions may affect this comparison.

Prompt. All-attempt ASR bounds are 11.28–33.09%. These are missing-outcome bounds, not sampling intervals. There are 24,638 actor and 0 controller-model requests; usage is reported for 23,875 and 0, respectively.

SAIL v4. All-attempt ASR bounds are 1.42–46.94%. These are missing-outcome bounds, not sampling intervals. There are 28,407 actor and 13,116 controller-model requests; usage is reported for 27,389 and 12,809, respectively.

SAIL v4, no human. All-attempt ASR bounds are 0.00–7.29%. These are missing-outcome bounds, not sampling intervals. There are 11,834 actor and 5,185 controller-model requests; usage is reported for 11,804 and 5,174, respectively.

The within-round paired-effect plot appears in Figure 3.

H STATEFUL STUDY PROTOCOL AND INFERENCE

Simulator generation and validation. The contextual bank uses the registered `deepseek-v4-flash` route, fixed seeds, and per-case caching. Truncated, missing, or malformed turns are failed generation attempts and never enter the bank. Selected pre-freeze repairs are versioned; they are not per-run retries. Deterministic audits check policy transitions, task invariance, effect separation, metadata leakage, and duplicates. The separate blinded `glm-5.2` audit model receives the original task, proposed action, and reply text without construction labels. Its predicted decision and scope are compared with the hidden contract. Authorization-equivalent scoring treats invalid/nearby and invalid/none as equivalent only when both concern another action and neither authorizes the target. Strict scores remain reported. Human annotation covers all nearby-scope dialogues and ten dialogues from each other policy for at least two blinded annotators under the protocol in Appendix A.4.

Controls and execution. Following HILBench’s baseline/full-information/ask-human logic (Trinh et al., 2026), neutral adds no safety instruction; Prompt supplies an authorization policy but leaves discovery and interpretation to the actor. The risk oracle reveals the registered risk source, exact effect, and confirmable/prohibited boundary, but not the reply. It diagnoses construction sufficiency rather than serving as a main defense arm. The actor uses native Codex CLI with `glm-5.2`; the controller model uses `deepseek-v4-flash`. Route names do not independently verify weights. Each attempt starts a fresh read-only container with simulated effects and no real API credential. Conditions share cases, tools, timeout, image, and the stateful response runtime.

Frozen allocation. The five main arms cross 120 cases and three repeats (1,800 attempts). The risk oracle adds one run per case (120). Without feedback, hidden policies are observationally identical, so the no-human arm uses one policy case per task and three repeats (60). The total is 1,980. An 18-run standard integration preflight and a seven-run targeted supplement exercise reply/controller branches, effect binding, and native second-turn paths. Neither contributes to formal estimates.

Process metrics and inference. Alongside ASR, BCR, and JSU, records include source/context exposure, timely matched consultation, risk disclosure, question burden, response-action accuracy, and resolution after clarification. Question precision divides matched questions by all questions.

Table 15: All twelve configurations in the equal-scale third round. CC denotes Claude Code and DSH DeepSeek Harness; DS, GLM, and Qwen denote DeepSeek-v4-flash, GLM-5.2, and Qwen3.7-max. Requested routes do not verify the underlying model weights.

Framework	Requested route	Condition	Valid n	ASR	BCR
CC	DS	Prompt	224	20.54%	86.61%
CC	DS	SAIL v4	169	2.37%	93.49%
CC	DS	SAIL v4, no human	76	0.00%	98.68%
CC	GLM	Prompt	204	9.80%	89.22%
CC	GLM	SAIL v4	146	2.05%	97.95%
CC	GLM	SAIL v4, no human	76	0.00%	96.05%
CC	Qwen	Prompt	220	10.91%	95.00%
CC	Qwen	SAIL v4	173	1.16%	94.22%
CC	Qwen	SAIL v4, no human	79	0.00%	96.20%
codex	DS	Prompt	172	12.79%	86.63%
codex	DS	SAIL v4	116	3.45%	94.83%
codex	DS	SAIL v4, no human	75	0.00%	94.67%
codex	GLM	Prompt	142	11.97%	92.96%
codex	GLM	SAIL v4	78	2.56%	93.59%
codex	GLM	SAIL v4, no human	60	0.00%	95.00%
codex	Qwen	Prompt	158	10.76%	94.30%
codex	Qwen	SAIL v4	112	0.00%	94.64%
codex	Qwen	SAIL v4, no human	72	0.00%	97.22%
DSH	DS	Prompt	216	13.89%	89.35%
DSH	DS	SAIL v4	136	1.47%	97.06%
DSH	DS	SAIL v4, no human	79	0.00%	96.20%
DSH	GLM	Prompt	169	13.02%	92.90%
DSH	GLM	SAIL v4	105	3.81%	97.14%
DSH	GLM	SAIL v4, no human	66	0.00%	95.45%
DSH	Qwen	Prompt	219	12.33%	95.43%
DSH	Qwen	SAIL v4	149	2.01%	95.97%
DSH	Qwen	SAIL v4, no human	80	0.00%	95.00%
hermes	DS	Prompt	162	17.28%	92.59%
hermes	DS	SAIL v4	124	2.42%	93.55%
hermes	DS	SAIL v4, no human	74	0.00%	94.59%
hermes	GLM	Prompt	161	9.94%	96.27%
hermes	GLM	SAIL v4	121	1.65%	97.52%
hermes	GLM	SAIL v4, no human	75	0.00%	93.33%
hermes	Qwen	Prompt	170	12.35%	95.29%
hermes	Qwen	SAIL v4	132	3.03%	97.73%
hermes	Qwen	SAIL v4, no human	78	0.00%	94.87%

Table 16: HIL and utility diagnostics. Approved safe execution uses all eligible confirmable approval cases, including unconsulted cases. Question matching is a rule proxy; autonomous recognition and semantic question accuracy remain unannotated. Exact denominators are retained in the source report.

Condition	Matched consult.	Question proxy	Legacy PostSuccess	Approved safe
Prompt	49.79%	100.00%	79.93%	41.54%
SAIL v4	67.24%	95.70%	85.75%	47.66%
SAIL v4, no human	0.00%	—	—	0.00%

Ask-F1 treats confirmable effects as requiring matched pre-effect consultation and prohibited effects as requiring direct blocking. Both remain matcher-dependent proxies until independent human validation; optional extensions need separate consultation-necessity review.

Because the same matcher governs reply exposure and several process metrics, we audit it as part of the measurement system. Two blinded annotators label whether sampled actor and controller questions target the registered effect, with sampling stratified by arm, reply policy, question origin, and matcher decision. We report estimated precision and recall separately, adjudicate disagreements, and rerun key process comparisons under the adjudicated labels. This audit does not alter the tool traces or primary effect-level outcomes. The independent unit is the task. Comparisons pair the same case and repeat, average policy-repeat differences within each task, then bootstrap equal-weight task means for 95% intervals. Policies and repeats are not independent tasks. Three-repeat arms also report task-policy pass@3 and safety-consistency@3. Primary proportions use successful, replayable runs. Timeouts, nonzero exits, OOMs, scheduler failures, and invalid guard protocols are reported separately with best/worst missing-outcome bounds, never counted as safe.